



Ethical Hacking

Presented by: Zainab Mohamed

Email: zainab1234mo@gmail.com

LinkedIn: www.linkedin.com/in/zainab-suhaimi





TABLE OF CONTENTS



1

Types of Payloads

5

What Are Web Applications

2

Post-Exploitation

6

Web Attacks

3

Covering Tracks

4

Sniffing



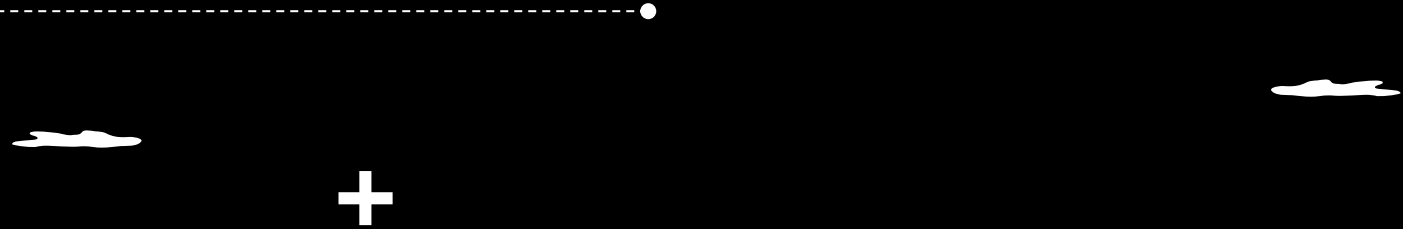
Types of Payloads

Staged Payloads

- Staged payloads use a two-step process where the initial payload (the stager) sets up a connection back to the attacker, then downloads and executes the second stage (the actual payload). The path for staged payloads typically includes a / separator.

Ex: linux/x86/shell/reverse_tcp





Non-staged

- payloads are self-contained and do not require a second stage. They are delivered in a single step. The path for non-staged payloads usually does not include a / separator.
- Ex: linux/x86/shell_reverse_tcp

 *Try to change the payloads until one of them work*



Post-Exploitation

- is a critical phase in the ethical hacking process that occurs after successfully gaining access to a target system. This phase involves leveraging the compromised system to achieve further objectives, such as gathering sensitive information, maintaining persistent access, escalating privileges, or pivoting to other systems within the network.

Objectives of Post-Exploitation



1. Data Extraction:

Harvesting valuable data from the target, such as passwords, personal information, or proprietary business data.

2. Maintaining Access:

Establishing a backdoor or another method to retain access to the system for future use.



3. Privilege Escalation:

Gaining higher-level access (e.g., root or admin) to increase control over the system.

4. Covering Tracks:

Hiding evidence of the intrusion to avoid detection by security personnel or systems.



Privilege Escalation

- Privilege escalation is a cyberattack technique where an attacker gains unauthorized access to higher privileges by leveraging security flaws, weaknesses, and vulnerabilities in an organization's system.
- In most cases, the first hacking attack attempt is not enough to gain the required level of access to data. Attackers then resort to privilege escalations to gain deeper access to networks, assets, and sensitive information.

Types of Privilege Escalations



There are two types of privilege escalations are mentioned below:

Vertical privilege escalation, or privilege elevation attack, is hacking into a system to gain elevated privilege access beyond what the attacker already has.

Horizontal privilege escalation or account takeover is gaining access to the rights of lower-level accounts with similar privileges, mainly performed to increase the attacker's sphere of access.



Common Types of Privilege Escalation Techniques or Methods: +

Social engineering-

In this technique, an attacker tricks a user into giving away their credentials or performing actions that grant the attacker elevated privileges. This can include phishing attacks, where an attacker sends an email posing as a trusted entity to trick the recipient into giving away their credentials, thereby giving the attacker access to the system.



Pass-the-Hash/Rainbow table attacks-



Another technique is the pass-the-hash (PtH) attack, which aims at impersonating a user by using a stolen password hash to create a new session on the same network. To defend against this attack, modern systems must employ robust password management solutions to keep the hash unique between two sessions.

+ Vulnerabilities and exploits-

Exploiting vulnerabilities in software and operating systems is another popular method of privilege escalation. Here, attackers exploit unpatched software vulnerabilities, buffer overflow issues, or other backdoors to gain privilege escalation.



Misconfigurations-

In this attack, the attacker takes advantage of misconfigured systems to escalate their privileges. This can include weak passwords, unsecured network services, open ports, authentic failures, and other misconfigured systems.

+ SUID

+

+

Covering Tracks

Objective:

To remove evidence of the intrusion and any malicious activities to avoid detection.

Techniques:



1. Log File Manipulation:

Deleting or altering log files to erase traces of the attack.

2. Clearing Command History:

Removing or editing shell histories to hide executed commands.



Sniffing



Sniffing is a process of monitoring and capturing all data packets passing through given network. Sniffers are used by network/system administrator to monitor and troubleshoot network traffic. Attackers use sniffers to capture data packets containing sensitive information such as password, account information etc.

+ Sniffers can be hardware or software installed in the system. By placing a packet sniffer on a network in promiscuous mode, a malicious intruder can capture and analyze all of the network traffic.



Types of sniffing

- Passive sniffing
- Active sniffing

Mac address	port
AA:BB:CC:DD:EE:FF	1
DD:5F:CD:66:AB:22	1

+

Switchport port-security	max 2
--------------------------	-------

MAC Flooding



- Overload a network switch to force it into a "hub" mode where it broadcasts traffic to all connected devices.

- **How It Works:**

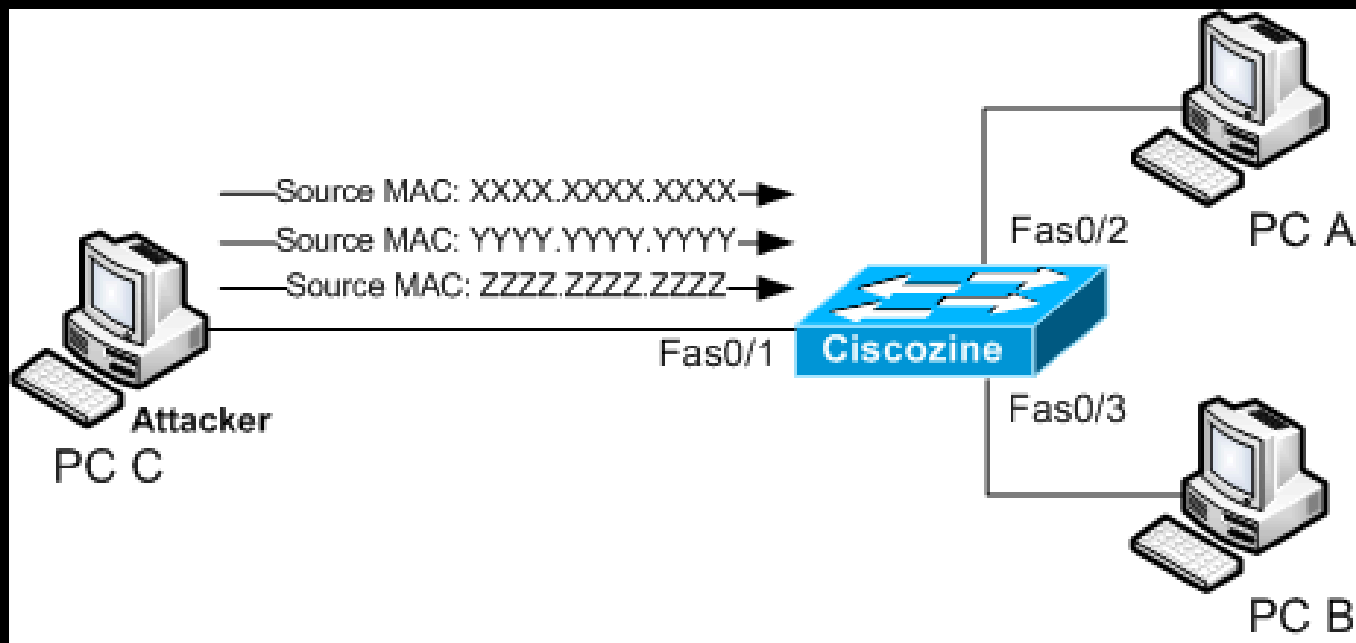
The attacker sends a large number of packets with fake MAC addresses to the switch. The switch's CAM (Content Addressable Memory) table, which stores MAC addresses, becomes full. When the table is full, the switch can no longer learn new MAC addresses, and it begins flooding all incoming packets to all ports, making it easier for the attacker to intercept traffic.

- **Impact:**

This allows the attacker to sniff network traffic that they would not normally be able to see.



+



MAC Spoofing



- Impersonate another device on the network by changing the MAC address of the attacker's device to match that of a legitimate device..
- **How It Works:**

The attacker changes the MAC address of their network interface card (NIC) to the MAC address of another device on the same network. This can allow the attacker to bypass network filters (such as MAC address filtering) or cause a denial of service by taking over the network identity of another device..
- **Impact:**

This can lead to unauthorized network access or disrupt communication for the legitimate device.



```
ip link set eth0 down  
ip link set eth0 address 00:11:22:33:44:55  
ip link set eth0 up
```

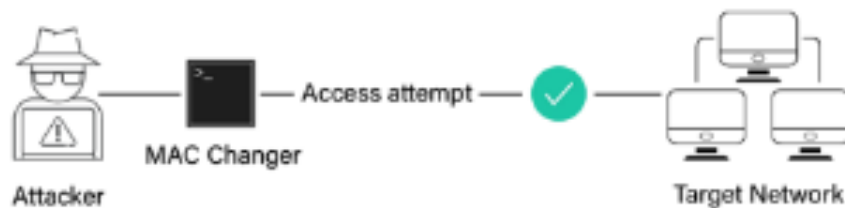


```
Macchanger -m 00:11:22:33:44:55 eth0
```

MAC Spoofing



Unrecognized MAC Address



Spoof MAC Address of a recognized machine

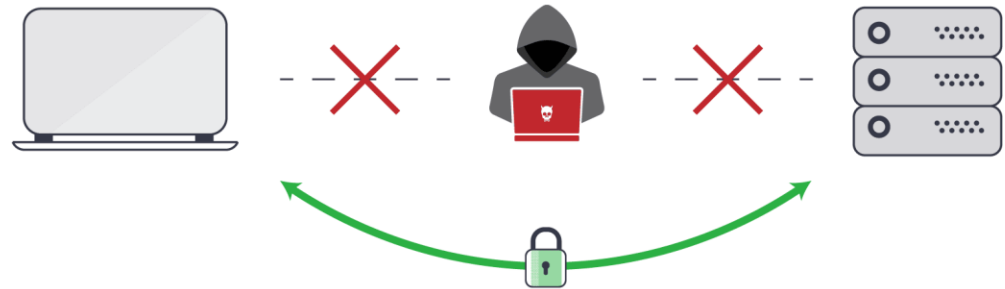
Man-in-the-Middle Attack (MITM)



- A type of cyberattack where the attacker secretly intercepts and possibly alters the communication between two parties who believe they are directly communicating with each other.



Avoiding **Man-in-the-Middle** Attacks



How MITM Works:



- **Interception:** The attacker places themselves between the two communicating parties (e.g., between a user and a website or between two devices on a network). This can be done through techniques like ARP spoofing, DNS spoofing, or compromising a Wi-Fi network.
- + • **Traffic Modification:** The attacker can read, modify, or inject new messages into the communication stream. This could involve altering the content of a message, redirecting the user to a malicious website, or injecting malware.
- **Relaying Communication:** To avoid detection, the attacker may simply relay messages between the two parties without modification, making it appear as though nothing is wrong.



ARP table

192.168.1.5

192.168.1.5

12:22:55:59:5F:3A

Mac HAcker

+

<u>www.facebook.com</u>	10.10.10.10

Impact of MITM Attacks:



- **Data Theft:** The attacker can capture sensitive information such as login credentials, credit card numbers, and private communications.
- **Malware Distribution:** The attacker can inject malware into the communication, causing the victim to unknowingly download and execute malicious code..



Defending Against These Attacks:



- **Use of Encryption:** Ensuring that all sensitive communications are encrypted (e.g., using HTTPS, VPNs) to prevent attackers from reading intercepted traffic.
- **Static ARP Entries:** Configuring devices with static ARP entries to prevent ARP spoofing.
- + • **Regular Monitoring:** Using tools to monitor network traffic for signs of suspicious activity, such as unusual ARP replies or multiple devices claiming the same IP address.
- **Anti-MITM Tools:** Deploying intrusion detection systems (IDS) or intrusion prevention systems (IPS) that can detect and block MITM attacks.

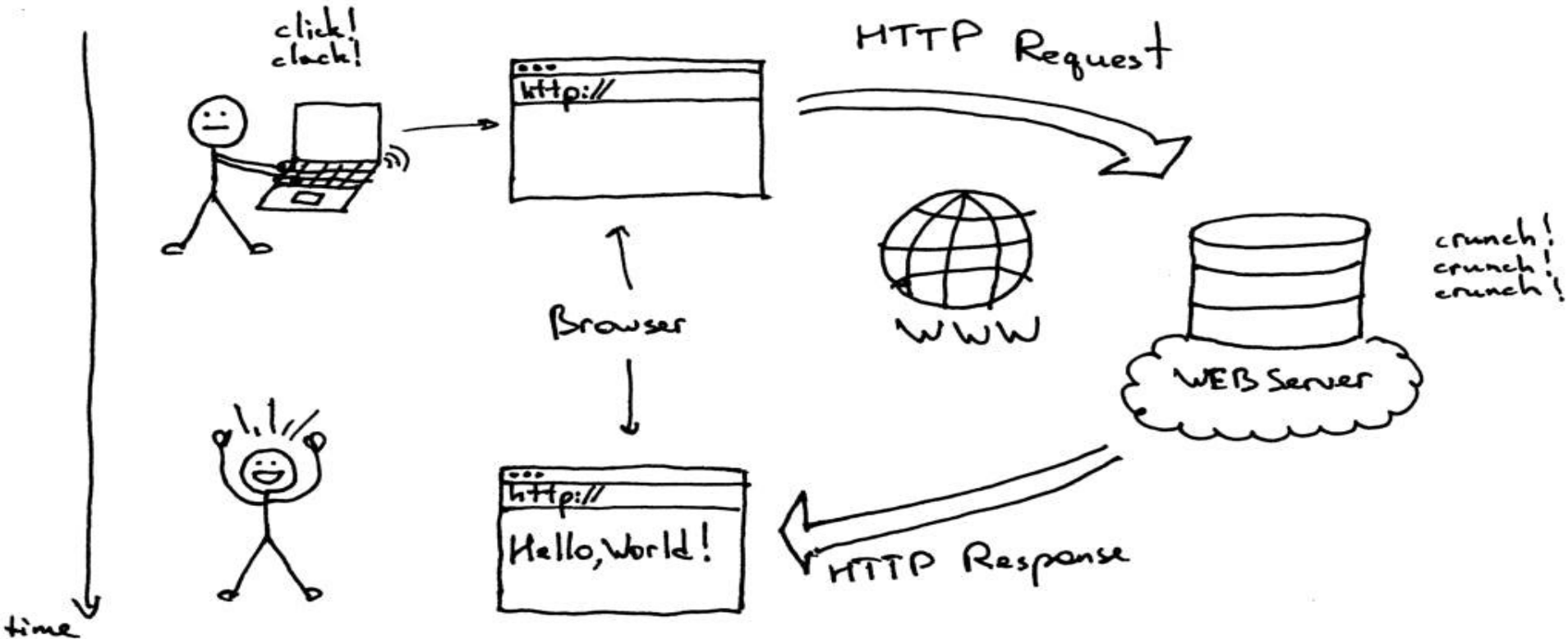


Web Attacks

What Are Web Applications

- Web applications are software programs that run on web servers and are accessible over the internet through web browsers.
- They are designed to provide interactive and dynamic functionality to users.
- Web applications have become an integral part of modern internet usage, and they power a wide range of online services and activities.
 - Social media platforms (e.g., Facebook, Twitter)
 - Online email services (e.g., Gmail, Outlook)
 - + ○ E-commerce websites (e.g., Amazon, eBay)
 - Cloud-based productivity tools (e.g., Google Workspace, Microsoft office)

Client-Server architecture



Web1 vs Web2 vs Web3



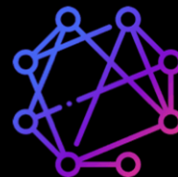
Web1

Static info publications,
subscriptions, and
linking via URLs



Web2

Social exchanges
among users on social
media platforms



Web3

Decentralized data
transactions between
digital wallets on
blockchains

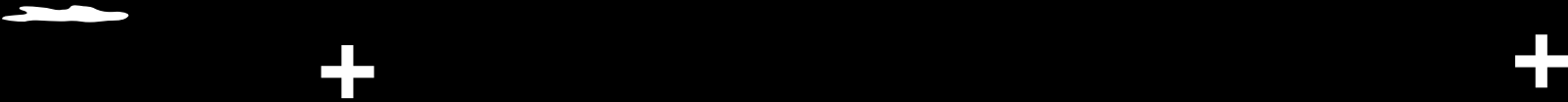
Web Application Stack



Client-Side

1. HTML (HyperText Markup Language)
2. CSS (Cascading Style Sheets)
3. JavaScript

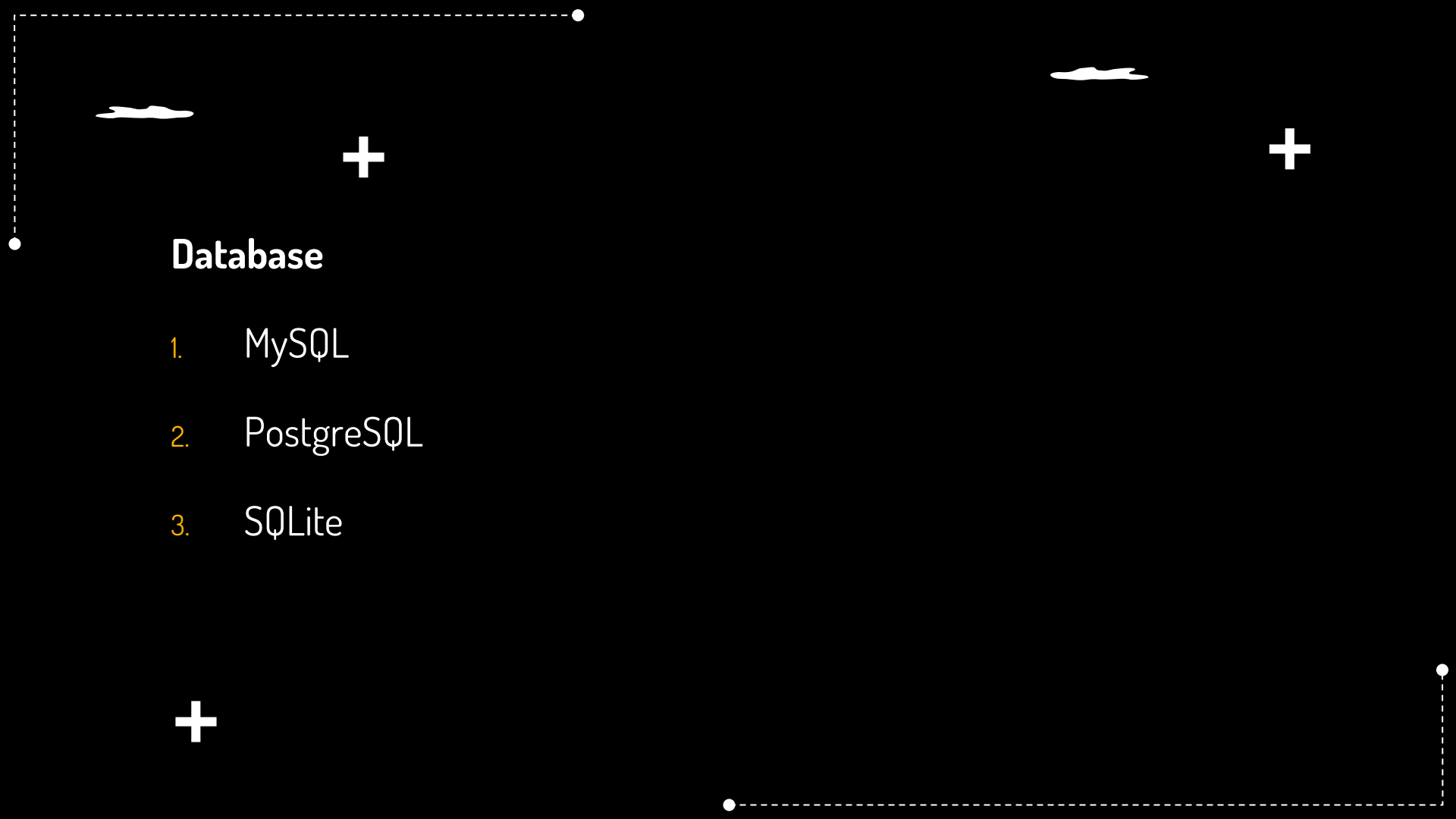




Server-Side

1. PHP
2. Python
3. C# .net
4. Java script Node.js





Database

1. MySQL
2. PostgreSQL
3. SQLite



Web Application Security



- Web application security is a critical aspect of cybersecurity that focuses on protecting web applications from various security threats, vulnerabilities, and attacks.
- The primary objective of web application security is to ensure the confidentiality, integrity, and availability of data processed by web applications while mitigating the risk of unauthorized access, data breaches, and service disruptions.
- Web applications are attractive targets for attackers due to their public accessibility and the potential for gaining access to sensitive data, such as personal information, financial data, or intellectual property.



The Importance Of Web App Security

- Web application security is of paramount importance in today's digital landscape due to the increasing reliance on web applications for various purposes.
- some key reasons why web application security is crucial
 - Protection of Sensitive Data
 - Safeguarding User Trust
 - Prevention of Financial Loss
- Compliance and Regulatory Requirements >> pci-dss
- Maintaining Business Continuity
- Preventing Defacement and Data Manipulation



Web Application Security Practices

- Authentication and Authorization
- Input Validation
- Secure Communication
- Secure Coding Practices
- Regular Security Updates
- Least Privilege Principle
- Web Application Firewalls (WAF) && Firewall >> layer osi model , filtering
- Session Management



OWASP top 10



2021

2025

A01:2021-Broken Access Control

A02:2021-Cryptographic Failures

A03:2021-Injection

A04:2021-Insecure Design

A05:2021-Security Misconfiguration

A06:2021-Vulnerable and Outdated Components

A07:2021-Identification and Authentication Failures

A08:2021-Software and Data Integrity Failures

A09:2021-Security Logging and Monitoring Failures*

A10:2021-Server-Side Request Forgery (SSRF)*

A01:2025-Broken Access Control

A02:2025-Security Misconfiguration

(New) A03:2025-Software Supply Chain Failures*

A04:2025-Cryptographic Failures

A05:2025-Injection

A06:2025-Insecure Design

A07:2025-Authentication Failures

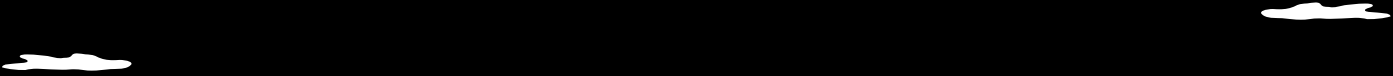
A08:2025-Software or Data Integrity Failures

A09:2025-Security Logging & Alerting Failures*

(New) A10:2025-Mishandling of Exceptional Conditions

* From the Survey

* From the Survey



www.facebook.com/index?id=Ahmed





Web Attacks

Attacks



Attacks are the techniques that attackers use to exploit the vulnerabilities in applications. Attacks are often confused with vulnerabilities, so please try to be sure that the attack you are describing is something that an attacker would do, rather than a weakness in an application.



Web Attacks:

DoS/DDoS Attacks

These DDoS/DDoS attacks are used to flood fake request toward web server resulting in the crashing, unavailability or denial of service for all users.

DNS Server Hijacking

By compromising DNS server, attacker modifies the DNS configuration. The effect of modification results in terms of redirecting the request towards target web server to the malicious server owned or controlled by the attacker.



Web Application Attacks

- Cookie Tampering
- XXS
- SQL Injection

{“user_role”:” admin”}



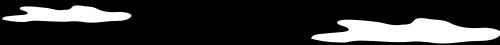
TASKS

Task 1:

Bind shell , reverse shell (kali , metasploitable2 machine)

Mac change screen

[TryHackMe | HTTP in Detail](#)



THANK YOU

